Cybercrime: Mobile and Wireless Devices

Acknowledgement

- **Cyber Security** by Nina Godbole, Sunit Belapure, Wiley India

Introduction

- **Laptops, PDAs and Mobile phones**
- **Managing** these devices **out side the walls** of the office
- **Remote connections**
- Many users bring these **devices from home** and **use them in the office**
- Large and **more diverse community of mobile users and their devices** increase the demands on the IT function to secure the device, data and connection to the network

Proliferation of mobile and wireless devices

Figure 3.1 | Typical hand-held devices.
Source: Nina Godbole (2009), *Information Systems Security: Security Management, Metrics, Frameworks and Best Practices*, Wiley India.

Proliferation of mobile and wireless devices

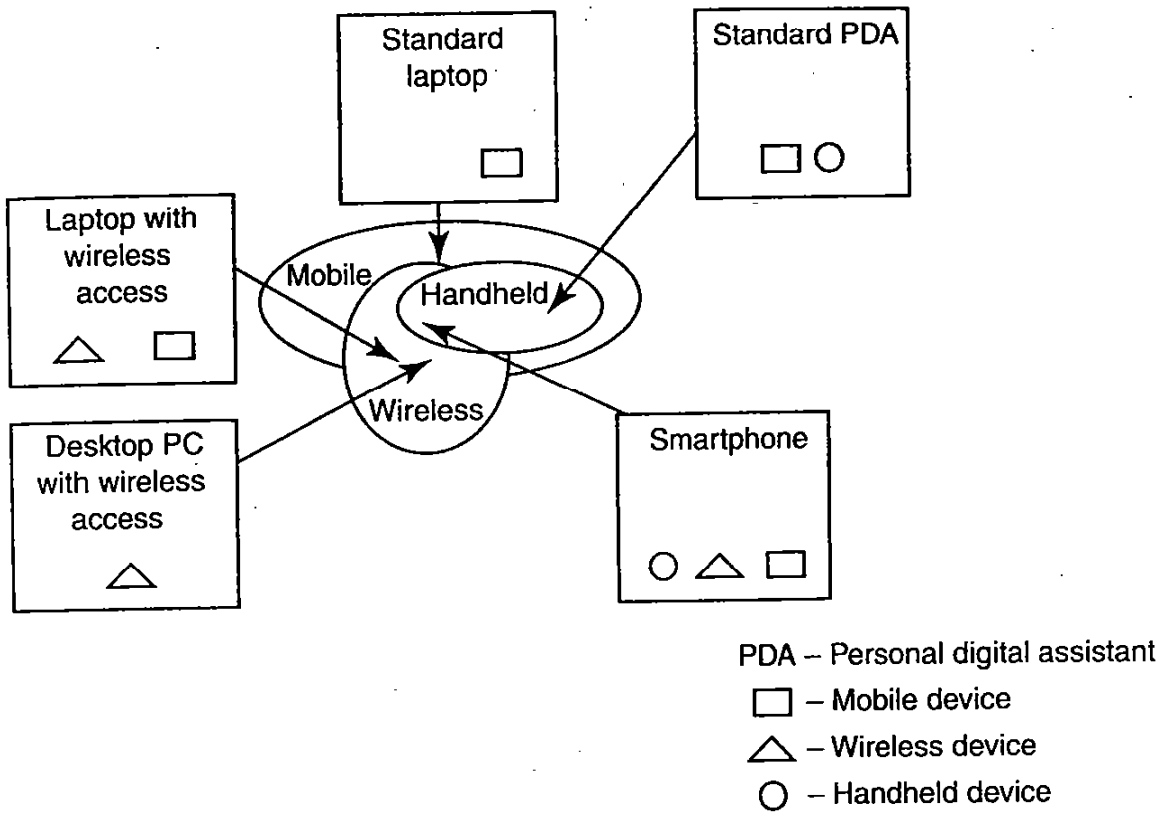

Figure 3.2 | Mobile, wireless and hand-held devices.
Source: Nina Godbole (2009), *Information Systems Security: Security Management, Metrics, Frameworks and Best Practices*, Wiley India.

Types of Mobile Computers

- Portable Computer
- Tablet PC
  - Touch-screen
- Internet Tablet
  - MP3 and Video player, Web browser, Chat application, picture viewer
- Personal Digital Assistant (PDA)
  - Pocket-sized with limited functionality, contacts, address book, notes, E-Mail etc.
- Ultramobile PC
  - PDA-sized with full featured and OS
- Smartphone
- Carputer
  - Installed in automobile with sound system, GPS, DVD player, Bluetooth
- Fly Fusion Pentop Computer
  - With the size and shape of a pen, writing utensil, MP3 player, language translator, digital storage device and calculator

Mobile Computing

- **Not necessarily require wireless communication**
- “Wireless” is a subset of “Mobile”
- **An application can be mobile without being wireless**
- Smart hand-held devices connect to wireless or cellular network

Trends in Mobility

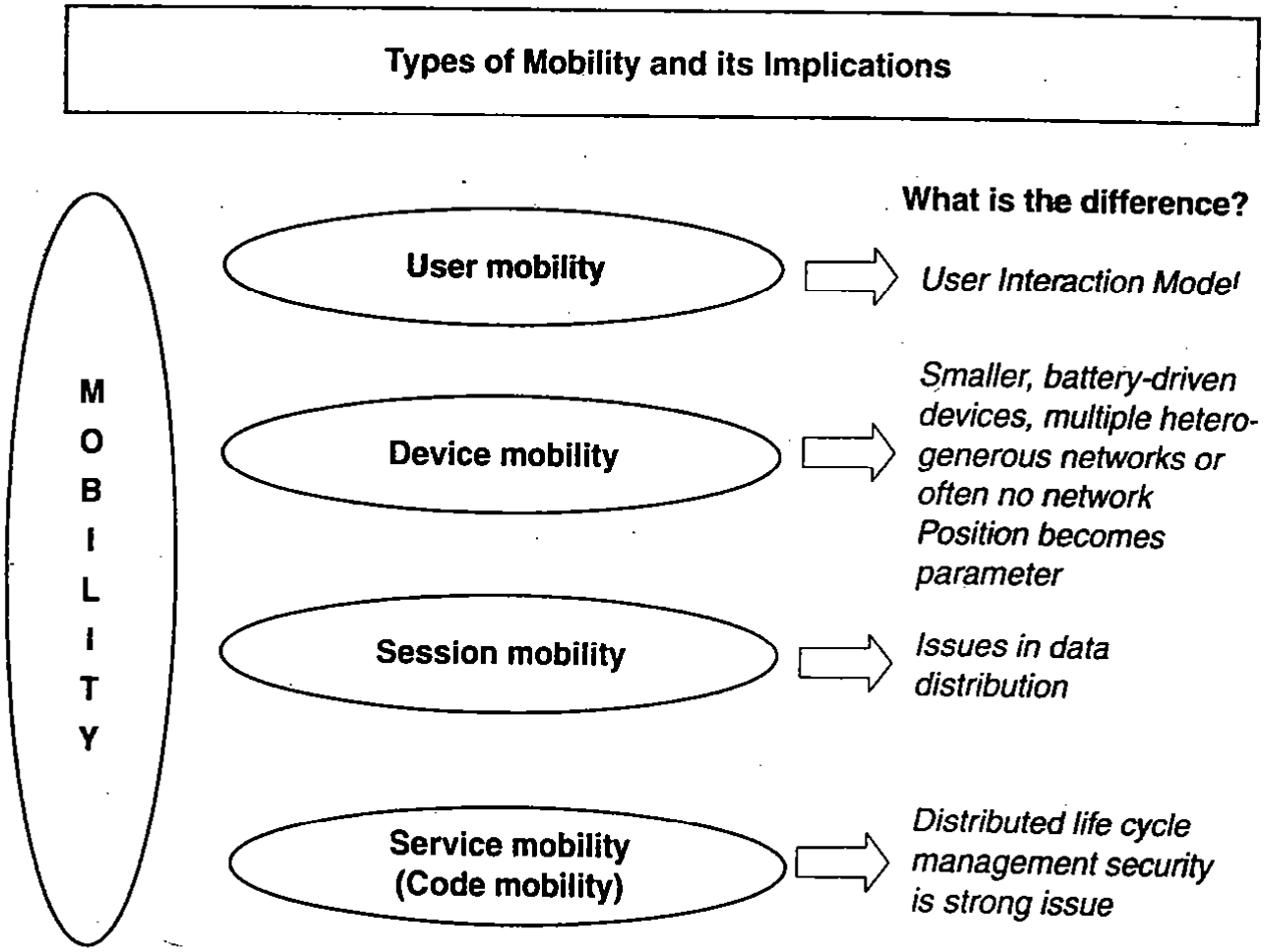

Figure 3.3 | Mobility types and implications.
Source: Nina Godbole (2009), *Information Systems Security: Security Management, Metrics, Frameworks and Best Practices*, Wiley India.

3G Mobile Networks

- 3G networks are **not** entirely built with **IP data security**
- **Attacks** that can be committed **against mobile networks** can **originate from two** primary vectors.
  - From **outside** the mobile network: public Internet, private networks and other operator's networks
  - **Within** the mobile networks: data-capable handsets and smartphones, notebook computers or desktop computers connected to 3G network

Popular types of attacks against 3G mobile networks:

- Malware, viruses and worms
  - Skull trojans, Cabir worm, Mosquito Trojan, Brador Trojan, Lasco Worm
- Denial-of-service
  - Make the system unavailable to the intended users
  - DDoS attacks are used to flood the target system with the data so that the response from the target system is either slowed or stopped.
  - Botnets / Zombies are used to create enough traffic
- Overbilling attack
  - Hijacking subscriber's IP address and then using to initiate downloads
- Spoofed policy development process
  - Exploits the vulnerabilities in the GTP (GPRS Tunneling Protocol)
- Signaling-level attacks
  - Session Initiation Protocol (SIP) is a signaling protocol used in IP Multimedia Subsystem (IMS) networks to provide VoIP.
  - Vulnerabilities with SIP-based VoIP systems

Skull trojan

- A trojan horse piece of code that targets mainly **Symbian OS**. Once downloaded, the virus **replaces all phone desktop icons** with images of a skull. It also renders all phone **applications useless**. This malware also tends to **mass text messages containing malicious links to all contacts** accessible through the device in order to spread the damage. This mass texting can also give rise to high expenses.

Cabir worm

- This malware infects mobile phones running on **Symbian OS** and was first identified in June 2004. When a phone is infected, the **message 'Caribe' is displayed on the phone's screen and is displayed every time the phone is turned on**. The worm then attempts to **spread to other phones** in the area **using** wireless **Bluetooth signals**, although the recipient has to confirm this manually.

Mosquito Trojan

- In June 2004, it was discovered that a company called Ojam had engineered an anti-piracy Trojan virus in older versions of its mobile phone game, *Mosquito.*
- This virus sent **SMS text messages** to the company without the user's knowledge.
- Although this malware was removed from the game's more recent versions, it still exists in older, unlicensed versions, and these may still be distributed on file-sharing networks and free software download web sites.

Malware, viruses and worms

- Brador Trojan
  - Affects **Windows CE OS** by creating **svchost.exe** file
- Lasco worm
  - Targets PDA and mobile phones running **Symbian OS**.
  - Based on Cabri's source code and replicates over Bluetooth connection

Credit Card Frauds in Mobile and Wireless Computing Era

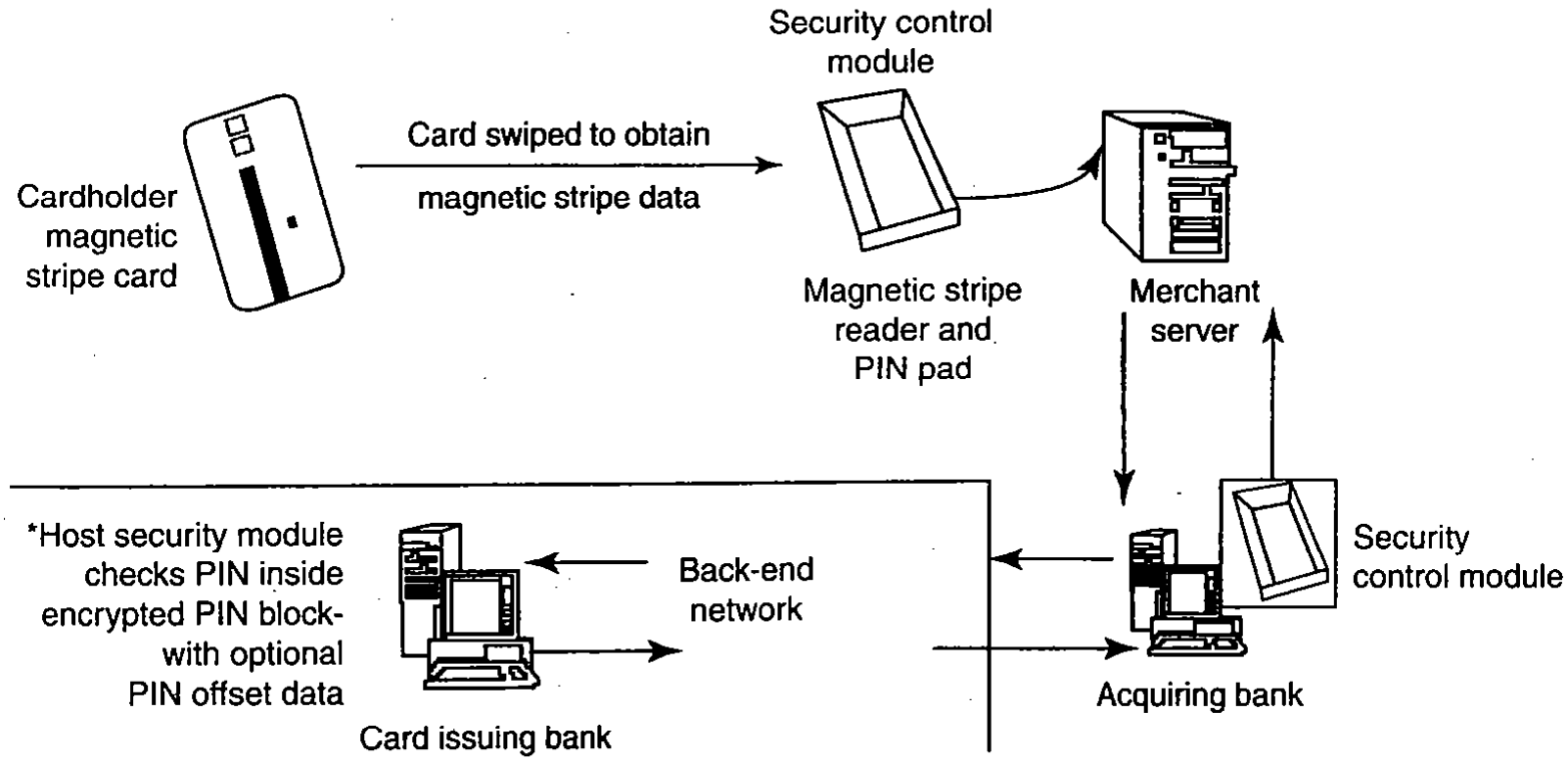

Figure 3.4 | Online environment for credit card transactions.
Source: Nina Godbole (2009), *Information Systems Security: Security Management, Metrics, Frameworks and Best Practices*, Wiley India.

Types and Techniques of Credit Card Frauds

- **Traditional techniques**
  - Application fraud (paper-based fraud: uses stolen or fake documents)
    - ID theft
      - Individual **pretends to be someone else**
    - Financial Fraud
      - Individual **gives false information about his or her financial status** to acquire credit card

Types and Techniques of Credit Card Frauds

- **Modern techniques**
  - Sophistic techniques enable criminals to produce fake and doctored cards
  - Skimming
    - **Information** held on either magnetic strip or data stored on smart chip are **copied from one card to another**
  - To **direct the users to cloned sites** and **false merchant sites** is called Phishing

Types and Techniques of Credit Card Frauds

- **Modern techniques**
  - Triangulation
    - Criminal offers **heavy discount rates** through a website
    - **Customer registers** with personal information and **credit card details**
    - **Criminal orders the goods** from legitimate website with the help of **stolen credit card**
    - **Goods are shipped** to the costumer and transaction gets completed
    - **Criminal keeps on purchasing other goods using fraudulent credit card details**
    - Such websites are available **for few weeks/months**
  - Credit Card generators
    - **Computer emulation software** available for free download on the Internet

Security challenges posed by mobile devices

- Information is being **taken outside** the physically controlled environment
- **Remote access** back to the protected environment is being granted
- One at the **device level**: **microchallenges**
- Another at the **organization level**: **macrochallenges**

Well know challenges in mobile security:

- Managing the registry setting and configuration
- Authentication Service Security
- Cryptography Security
- Lightweight Directory Access protocol(LADP) Security
- Remote Access Server(RAS) security
- Media Player Control Security
- Network Application Program Interface (API) security

Registry settings for mobile devices

- **Microsoft Active Sync** : synchronize PCs and MS Outlook
- Gateway between Windows-Powered PC and Windows mobile-Powered device
- Enables transfer of Outlook information, MS Office documents, pictures, music, videos and applications
- Active sync can **synchronize directly with MS Exchange Sever** so that the user can keep their E-Mails, calendar, notes and contacts updated wirelessly.

Managing the registry setting and configuration:

- If you use an **Active Directory** environment to administer the computers in your network, Group Policy provides a comprehensive **set of policy settings** to manage Windows® Internet Explorer® 8 after you have deployed it to your users' computers.
- You can use the **Administrative Template policy settings** to establish and lock registry-based policies for hundreds of Internet Explorer 8 options, including security options.
- 1700 settings in a standard group policy

Managing the registry setting and configuration:

- Even if the user go through every control panel setting and group policy option- **no desired baseline security**

- So **make additional registry changes** that are not exposed to any interface: avoid "**registry hacks**"

Authentication Service Security

Two components of security in mobile computing:

1. **Security of devices**
2. **Security in Networks**
   - Involves **mutual authentication** between the device and the base station/ servers.
   - Ensures that only **authenticated devices** can be connected to the network
   - Hence, **no malicious code can impersonate** the service provider to trick the device.

Eminent kinds of attacks on mobile devices:

- Push attacks
- Pull attacks
- Crash attack

Push Attack

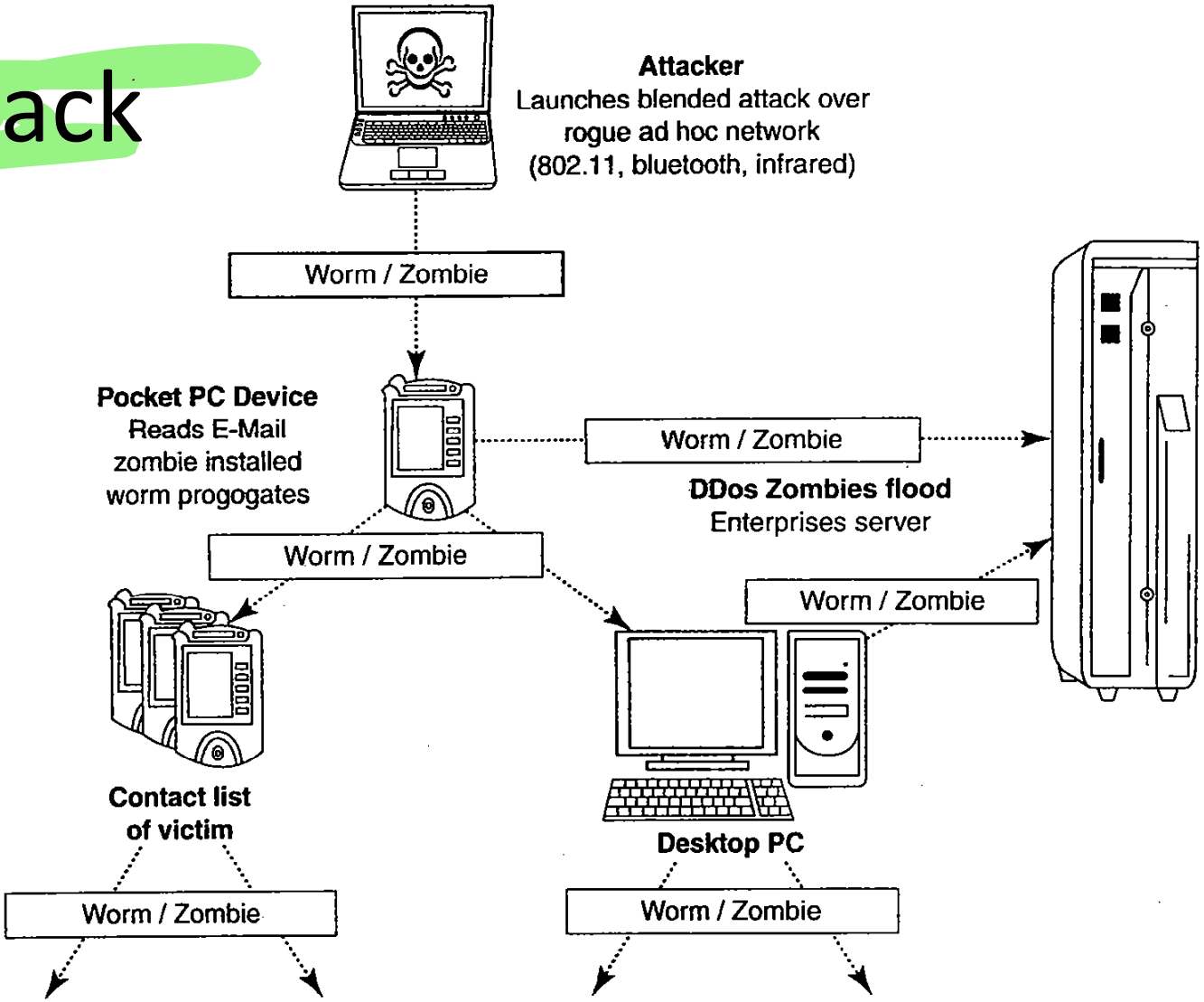

Figure 3.8 | Push attack on mobile devices. DDoS implies distributed denial-of-service attack. *Source:* Nina Godbole (2009), *Information Systems Security: Security Management, Metrics, Frameworks and Best Practices*, Wiley India.

Pull Attack

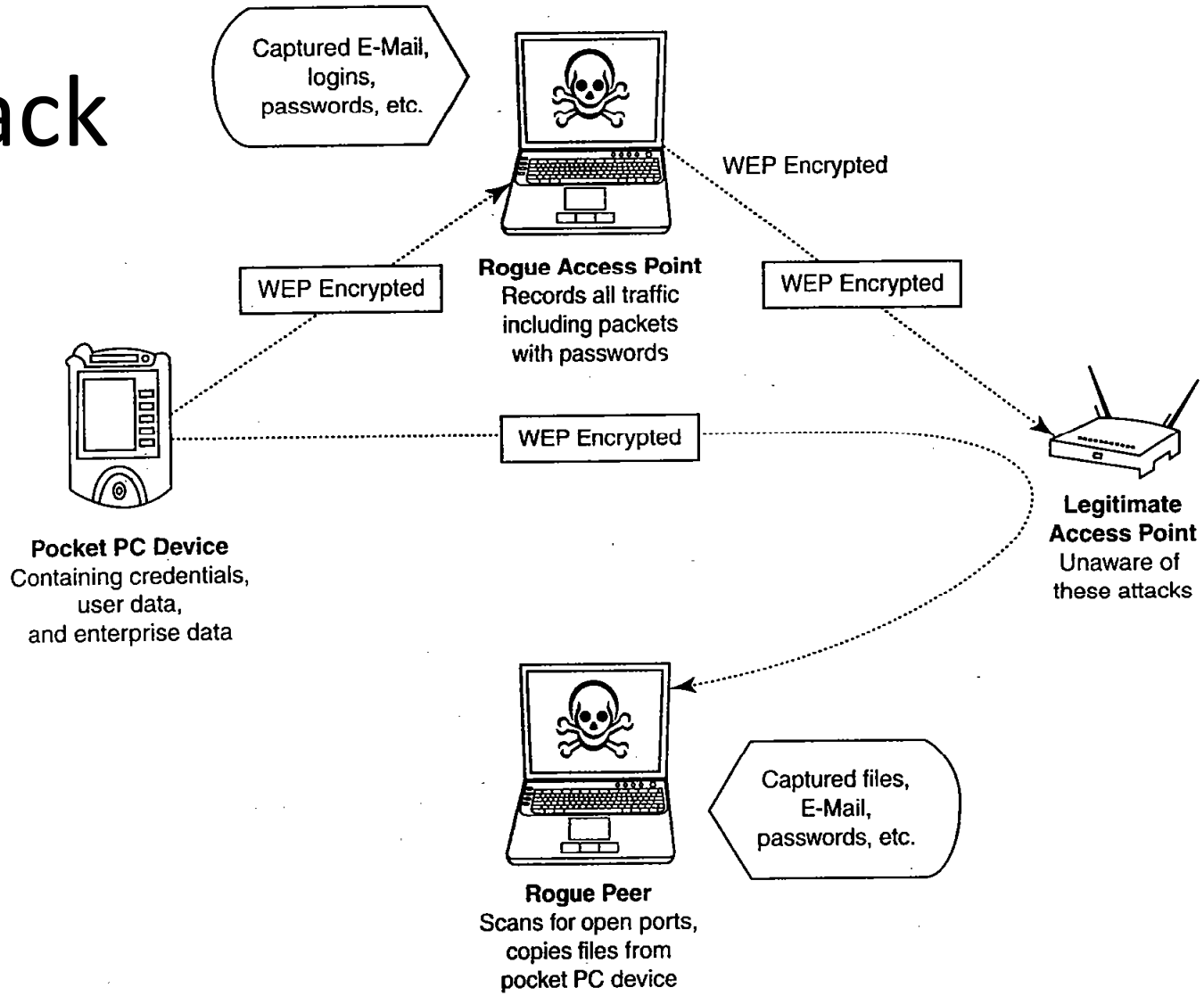

Figure 3.9 | Pull attack on mobile devices.
Source: Nina Godbole (2009), *Information Systems Security: Security Management, Metrics, Frameworks and Best Practices*, Wiley India.

Crash Attack

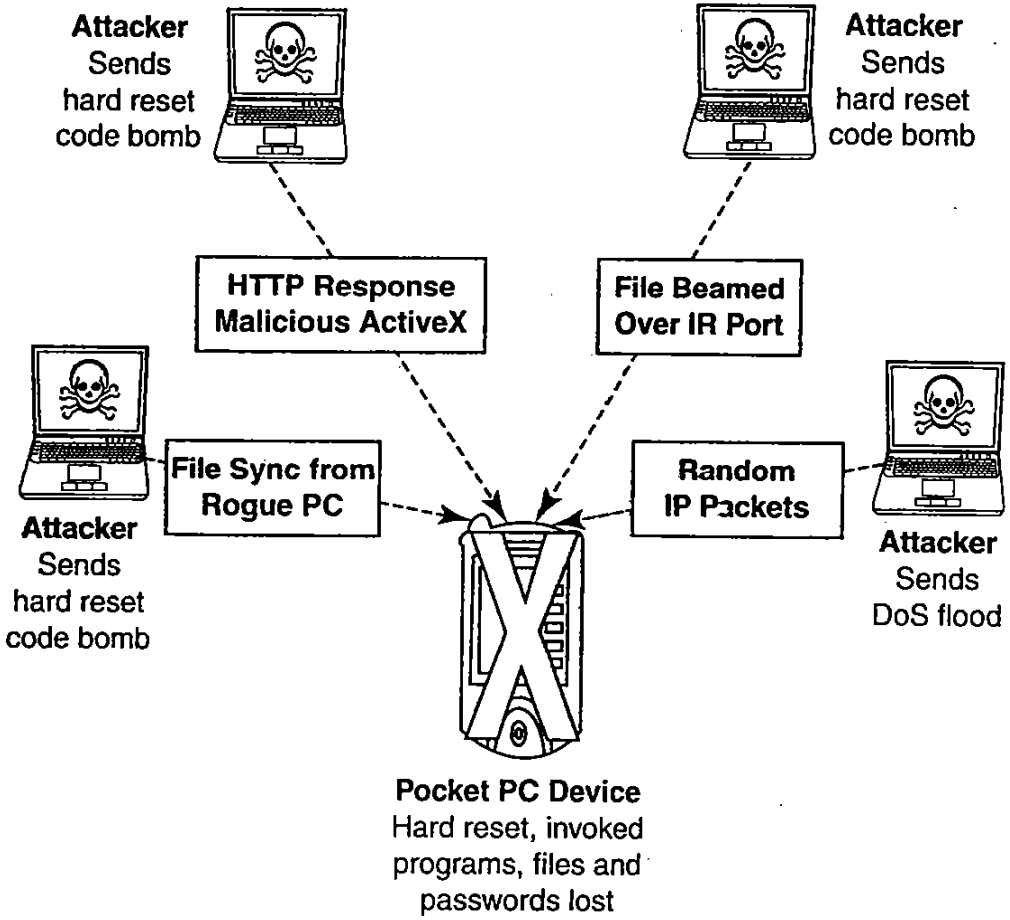

Figure 3.10 | Crash attack on mobile devices. DoS – Denial-of-service attack.
Source: Nina Godbole (2009), *Information Systems Security: Security Management, Metrics, Frameworks and Best Practices*, Wiley India.

Cryptographic Security for Mobile Devices

- Cryptographically Generated Address (CGA)
- **CGA is IPv6**: generated by **hashing owner's public-key address**
- The address the **owner uses** is the corresponding **private key** to **assert address ownership** and to sign **messages sent** from the address without a Public-Key Infrastructure(PKI)
- CGA-based Authentication can be used to **protect IP-Layer signaling protocols**
- Also used in key –exchange and create an IPSec security association for encryption and data authentication

Example: Palm OS5

- Cryptographic Provider Manage(CPM) in Palm OS5 is a system-wide suite of cryptographic services for securing data and resources on a Palm- powered device

LDAP security for hand held mobile computing devices

- LDAP is a software protocol for enabling anyone **to locate individuals, organizations and other resources like files and devices on the network**
- LDAP is light weight version of Directory Access Protocol(DAP) since it **does not include security** features in its initial version.
- It originated at the University of Michigan
- Endorsed by at least 40 companies
- **Centralized directories such as LDAP make revoking permissions quick and easy**.

LDAP directory Structure: simple tree structure

- Root directory
- Countries
- Organizations
- Organizational units
- individuals

RAS security for mobile devices

- RAS is **important** for protecting business sensitive data that may reside on the employee's mobile devices.
- **Vulnerable to unauthorized access** : resulting in providing a route into the systems with which they connect
  - By impersonating or masquerading to these systems, a cracker is able to steal data or compromise corporate systems in other ways.
- Another threat is by **port scanning**: DNS server- locate IP address- scan the port on this IP address that are unprotected.
- **Precautions**: a personal firewall
- For Corporate Network, place personal **firewall on the gateway**
- Deploying **secure access methods** that implement **strong authentication keys**

RAS security for mobile devices

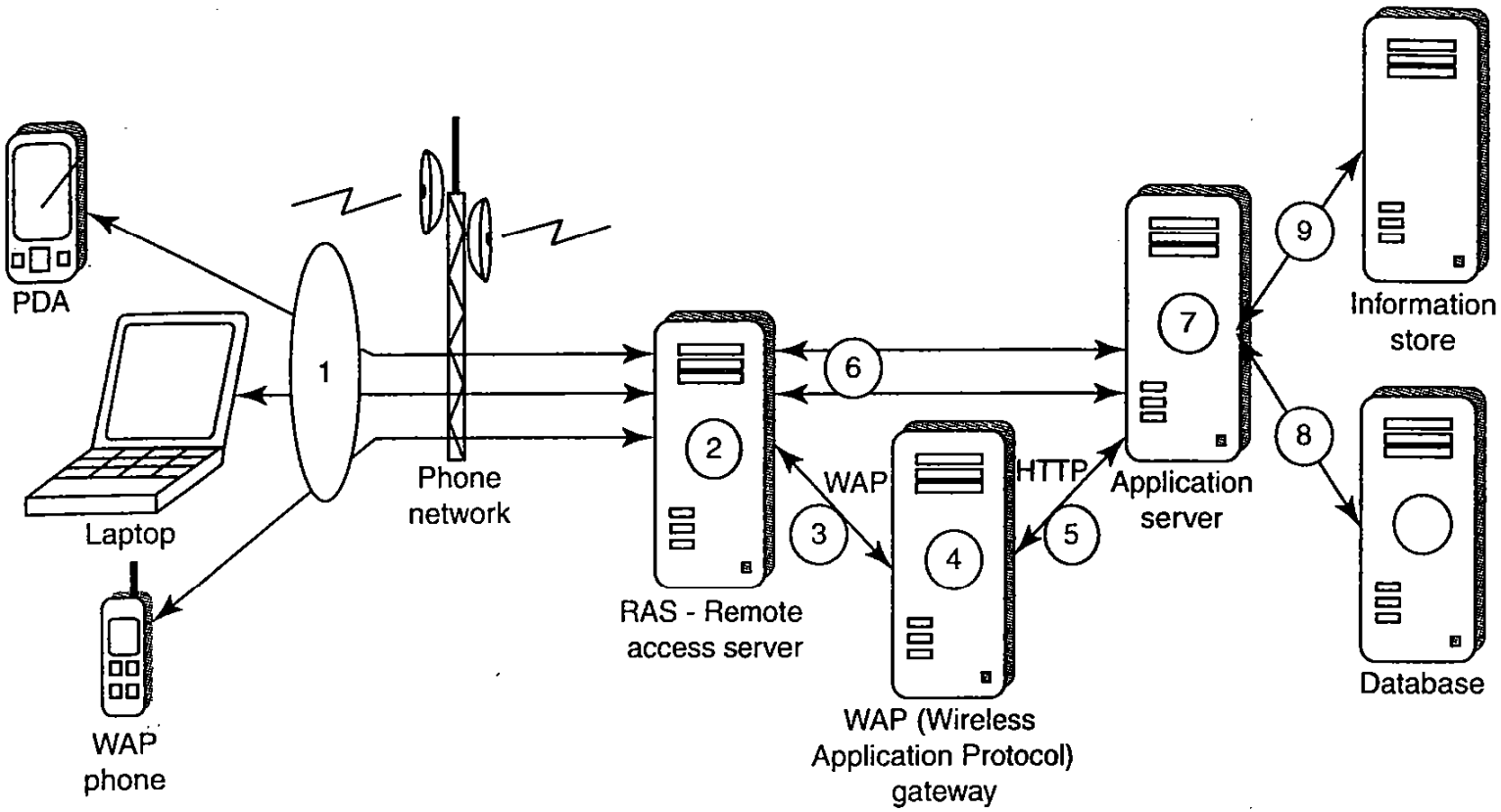

Figure 3.11 | Communication from mobile client to organization information store.
Source: Nina Godbole (2009), *Information Systems Security: Security Management, Metrics, Frameworks and Best Practices*, Wiley India.

RAS system security for Mobile device clients

- The security of the RAS server
- The security of the RAS client
- The secure data transmission

Media Player Control Security

- Potential security attacks on mobile devices through the "**music gateways**"
- Windows media player: MS warned about security loop holes
- **Corrupt files posing as normal** music and video files
  - May open a website from where the Javascript can be operated.
  - Allow attacker to download and use the code on user's machine
  - Create buffer overrun errors.

Networking API security for mobile computing applications

- Development of various API's to enable software and hardware developers to **write single applications to target multiple security platforms**
- Secure a range of embedded and consumer products

Attacks on Mobile/ cell phones

- Mobile Phone Theft
- Mobile Viruses
- Mishing
- Vishing
- Smishing
- Hacking bluetooth

Mobile phone theft

With mobiles or cell phones becoming fancier, more popular, and more expensive, they are increasingly liable to theft.

The following factors **contribute** for outbreaks on mobile devices:

1. **Enough target terminals:** first mobile virus in 2004 :- Mosquito – this virus sent SMS text messages to the organization (Ojam)
2. **Enough functionality:** office functionality, critical data and applications protected insufficiently or not at all.

   expanded functionality increases the probability of malware
3. **Enough connectivity:** SMS, MMS, Synchronization, bluetooth, infrared(IR) and WLAN connections

How to Protect a Mobile Phone from Being Stolen

- **Keep details.** Make a record of all your phone information and keep this in a safe place. Include the following elements in the information:
  - Your phone number
  - The make and model
  - Color and appearance details
  - The pin or security lock code
  - The IMEI number (on GSM phones)
    - International Mobile Equipment Identity

- **Add a security mark.** Use an **ultra violet pen** to print your post code and house number onto both your mobile handset and battery. This makes it easily identifiable as your property if lost or stolen. It would also be good if you **write your alternate contact number or email id** on your phone.
- This would help the finder of your handset to contact you if he or she intents to return it. The ultra-violet pen marking will wear off every couple of months, so reapply it when you feel necessary.

- **Use the security lock code, or PIN feature, to lock your phone.** This will make it **less valuable to a thief** and deny them access to personal numbers stored on your SIM card.

- **Register your phone with your network operator.** If your phone is stolen, report the loss to them immediately. Using **your IMEI number, they may be able to block your hand set and account details.**
- Some wireless carriers are willing to do this, and some aren't. If done, this will prevent anyone from using the phone across any network, even if the SIM card is changed. Keep in mind that once the phone is disabled, it may not be able to be used again, even if you get it back.
- Keep records of this call--the date, time, name of the person you spoke to, what they said, and their extension. Ask for confirmation in writing that your phone has been disabled. This is important in case the thief makes fraudulent charges on your account.

- **Have your phone number disabled.** In addition to reporting your phone lost or stolen, you should also disable your phone number (not account) so that no further charges can be applied. This is in case the thief figures out how to access your account through another hand set, or in case the carrier is unwilling to block the handset. Remember that, as mentioned earlier, many thieves stand to benefit from using your service rather than selling your phone, especially between the moment they steal it and the moment you realize your phone is missing. As in the previous step, keep detailed records of when you requested your account to be disabled.

- **Request an immediate, formal investigation from your carrier.** Sometimes this can prevent (or at least delay) the carrier from launching a collections effort and tainting your credit, if things get ugly.
- **File a police report immediately.** Time is money, literally. A thief can add over US$10,000 to your cell phone bill in just hours by making international calls, and you might end up being asked to foot the bill. Some phone companies may require proof that the phone was actually stolen, versus it having been lost. A police report serves as evidence, which will make your wireless provider more cooperative, especially if insurance is involved.

- **Install anti phone theft software.** There are suppliers that provide modern anti theft software for your phone. The software enables you to remotely contact your mobile and stay in control. For example, one of the recently published solutions for Symbian and Android is Theft Aware; others provide Windows Mobile or Blackberry support
- **Never let the phone get out of your sight.** Unless you are sleeping of course, always have your eyes on the phone.

Mobile Viruses

- 40 virus families
- 300+ mobile viruses identified
- First mobile virus : june 2004
- Spread through dominant communication protocols
  - Bluetooth
    - Spread within a distance of 10 – 30 m, through Bluetooth – activated phones
  - MMS
    - Can send a copy of itself to all mobile users in address book

How to protect from mobile malware attacks

- Download or accept programs and content only from a trusted source
- Turn off bluetooth or set it to non-discoverable when not in use
- Receive IR beams only from trusted source
- Install antivirus software

Mobile Phone Virus Hoax

- Forwarded messages claim that a destructive virus will infect your mobile (cell) phone if you receive a call that displays "ACE" or "XALAN" on the screen.

Example

- All mobile users pay attention!!!!!!!!!

  If you receive a phone call and your mobile phone displays(XALAN)on the screen don't answer the call, END THE CALL IMMEDIATELY,if you answer the call,your phone will be infected by a virus. This virus WILL ERASE all IMEI and IMSI information from both your phone and your SIM card, which will make your phone unable to connect with the telephone network. You will have to buy a new phone. This information has been confirmed by both Motorola and Nokia. There are over 3 Million mobile phones being infected by this virus in all around the world now. You can also check this news in the CNN web site.

  PLEASE FORWARD THIS PIECE OF INFORMATION TO ALL YOUR FRIENDS HAVING A MOBILE PHONE.

- Variants of this hoax have been circulating since 1999. The information in the email is completely untrue and has certainly not been "confirmed by both Motorola and Nokia".

Mishing

- 'Mishing' is a combination of the words Mobile phone and Phishing.
- Mishing is very similar to phishing—the only difference is the technology.
- **Phishing involves the use of emails to trick you into providing your personal details, whereas mishing involves mobile phones**.
- If you use your mobile phone for purchasing goods and services and convenient banking, you could be more vulnerable to a mishing scam.

Variants of Mishing

- **V**ishing : Mishing attacker **makes call** for phishing

- **S**mishing: Mishing attacker **sends SMS** for phishing

Vishing

- The term "vishing" is a socially engineered technique for **stealing information or money from consumers using the telephone network**.
- The term comes from combining "voice" with "phishing," which are online scams that get people to give up personal information.
- Vishing is very similar to phishing—the only difference is the technology.
- Vishing involves voice or telephone services. If you use a **Voice over Internet Protocol (VoIP) phone service, you are particularly vulnerable to a vishing scam**.
- Vishing is usually used to **steal credit card** numbers or other related data used in **ID theft** schemes from individuals.

Profitable uses of the information gained through a Vishing attack include:

- ID theft
- Purchasing luxury goods and services
- Transferring money/ funds
- Monitoring the victims bank accounts
- Making applications for loans and credit cards

How Vishing works?

- a vishing perpetrator (visher) may **gain access to a group of private customer phone numbers**.
- The visher may then call the group(may use **war dialer**)
- **When** a potential victim **answers** the phone, he or she hears an **automated recording** informing him that his **bank account has been compromised** and instructs to call a **specified toll-free number .**
- He then **calls the specified toll-free number to reset** his security settings and hears another automated message requesting the user's bank account number and/or other personal details via the phone keypad..

How to protect from Vishing attack?

- **Be suspicious of all unknown callers**
- **Don't trust caller ID**: caller ID spoofing is easy
- **Ask questions**: ask them to identify who they work for, and then check them out to see if they are legitimate.
- **Call them back**: call them back using a number from your bill or your card. Never provide credit card information or other private information to anyone who calls you
- **Report incidents**: to nearest cyberpolice cell

Smishing

- Short for **SMS Phishing**, smishing is a variant of phishing email scams that instead utilizes Short Message Service (SMS) systems to send bogus text messages.
- Also written as SMiShing, SMS phishing made recent headlines when a vulnerability in the iPhone's SMS text messaging system was discovered that made smishing on the mobile device possible.

How smishing works?

- Smishing scams frequently seek to **direct the text message recipient to visit a website or call a phone number**, at which point the person being scammed is enticed to provide sensitive information such as credit card details or passwords.
- Smishing websites are also known to attempt to **infect the person's computer with malware**.

Example

Text message originating from either notice@jpecu or message@cccu :

- ABC CU – has –deactivated – your Debit_card. To reactivate contact:210957XXXX

This is an automated message from ABC Bank.

- Your ATM card has been suspended. To reactivate call urgent at 1 866 215 XXXX

Text message originating from sms.alert@visa.com :

- sms.alert@visa.com/VISA. (Card Blocked) Alert. For more information please call 1-877-269-XXXX

How to protect from Smishing attacks?

- Do not answer a text message
- Avoid calling any phone numbers
- Never click on a hot link received through messages

Hacking bluetooth

- Bluetooth hacking is a technique used to **get information from another Bluetooth enabled device without any permissions from the host**.
- This event takes place due to security flaws in the Bluetooth technology.
- It is also known as **Bluesnarfing**.
- Bluetooth hacking is not limited to cell phones, but is also used to hack PDAs, Laptops and desktop computers.
- Bluetooth hacking is illegal and can lead to serious consequences.

Following are threats a person can face when his/her mobile phone gets bluesnarfed:

- The hacker **can steal, delete contacts**
- Hacker can **extract personal files/pictures** etc
- Your cell phone can be used for **making calls** and using internet at your expense
- The hacker may **call or text your contacts** to annoy them
- You mobile phone can be **reset to default factory settings** hence deleting your personal settings
- Hacker can even access your **calendar, clock, International Mobile Equipment Identity (IMEI) number**. IMEI number can be used to **clone your cell phone** so that your messages are also routed to another number. Cloning is also considered illegal.

Common attacks

- Bluejacking
- Bluesnarfing
- Bluebugging
- Car wishperer

Bluejacking

- ***Bluejacking*** is the **sending of unsolicited messages** over Bluetooth to Bluetooth-enabled devices such as mobile phones, PDAs or laptop computers,
- Sending a **vCard** which typically contains a message in the name field (i.e., for bluedating or bluechat) to another Bluetooth-enabled device .
- Bluejacking is also known as **bluehacking**.
- Bluejacking exploits a basic Bluetooth feature that allows devices to send messages to contacts within range.
- Bluejacking is **harmless**

Bluesnarfing

- **Bluesnarfing** is the unauthorized access of information from a wireless device through a Bluetooth connection, often between phones, desktops, laptops, and PDAs (personal digital assistant).
- This allows **access to a calendar, contact list, emails and text messages, and on some phones, users can copy pictures and private videos**.
- Both Bluesnarfing and Bluejacking exploit others' Bluetooth connections **without their knowledge**.
- While Bluejacking is essentially harmless as it only transmits data to the target device, **Bluesnarfing is the theft of information from the target device**.

Bluebugging

- **Bluebugging** is a form of Bluetooth attack often caused by a lack of awareness.
- It was developed after the onset of bluejacking and bluesnarfing. Similar to bluesnarfing, **bluebugging accesses and uses all phone features**
- Bluebugging manipulates a target phone into **compromising its security**, this **to create a backdoor attack** before returning control of the phone to its owner. Once control of a phone has been established, it is used to **call back the hacker who is then able to listen-in to conversations**.
- The Bluebug program also has the capability to **create a call forwarding application** whereby the hacker receives calls intended for the target phone.
- **Not only can a hacker receive calls intended for the target phone, he can send messages, read phonebooks, and examine calendars**.

Car Whisperer

- Software that **intercepts a hands-free Bluetooth conversation in a car**.
- The Car Whisperer enables **an attacker to speak to the driver as well as eavesdrop on a conversation**.
- By exploiting the fact that a common security code (passkey) is used by many Bluetooth hands-free system vendors, the Car Whisperer **sets up a two-way session with the car and a Linux computer**.
- An attacker could **access a telephone address book** once he has connected with the Bluetooth system,
- May **disable airbags or breaks**

- The best way to avoid being "Car Whispered" is to simply **connect the in-car system to a Bluetooth phone**, because only one such device can be connected at a time.

Bluetooth Hacking Tools

- BlueScanner
- BlueSniff
- BlueBugger
- BlueSnarfer
- BlueDiving

Mobile Devices: Security Implications for Organizations

- Managing diversity and proliferation of Hand-Held devices
- Unconventional/ stealth storage devices
- Threat through lost and stolen devices
- Protecting data on lost devices
- Educating the laptop users

Managing diversity and proliferation of Hand-Held devices

- Microissues at Organization level
- Employees aren't just bringing their mobile devices to the workplace—they're ***living* on them**
- As smartphones and tablets become **constant companions**, cyber attackers are using every avenue available to break into them.
- With the right (inexpensive) equipment, **hackers can gain access to a nearby mobile device in less than 30 seconds and either mirror the device and see everything on it, or install malware that will enable them to siphon data from it at their leisure**.

Managing diversity and proliferation of Hand-Held devices

- Analysts predict that by 2018, 25 percent of corporate data will completely **bypass perimeter security** and flow directly from mobile devices to the cloud.
- Chief information security officers (CISOs) and other security executives are finding that the **proliferation of mobile devices and cloud services are their biggest barriers to effective breach response**.
- In order to secure the corporate data passing through or residing on mobile devices, it is imperative to fully understand the issues they present.

Policy making efforts

- Organization needs to establish security practice subject to legal and external constraints
- **Policy making effort starts** with the commitment of CEO, president or Director who takes cybersecurity seriously
- **Mobile devices of the employees should be registered** in the corporate asset register
- **Close monitoring** of these devices
- **Physical access to corporate resources must be removed from mobile devices before the employee leaves**
- **Employees register their device with the IT department**: to control the access

Unconventional/ Stealth Storage devices

- Secondary storage devices
  - CDs
  - USBs
  - Portable external hard disks
- **Portable storage devices can be easily lost or stolen**.
- Decrease in size and emerge in new shape and sizes – difficult to detect
- Prime challenge for organizational security
- Firewalls and antivirus software are no defense against the open USB ports
- Remedy- block these ports, but Windows OS do not support
- Disgruntled employee can use these to download confidential data or upload harmful virus

Devicelock software

- **DeviceLock** provides network administrators the ability to **set and enforce contextual policies** for how, when, where to, and by whom **data can or can't be moved** to or from company laptops or desktop PCs via devices like phones, digital cameras, USB sticks, CD/DVD-R, tablets, printers or MP3 players.
- In addition, policies can be set and enforced for **copy operations** via the Windows Clipboard, as well as **screenshot operations** on the endpoint computer.

Stealth storage devices

Threats through lost and stolen devices

- Lost mobile devices are becoming even a larger security risk to corporations
- **Content is more important**, if lost or stolen, that can put a company at a serious risk of sabotage
- Mobile hand held devices are provided by the organization
- Wireless access to corporate network
- Users are more reliant on their mobile devices to store large amounts of sensitive information with few concerned about backing it up or protecting it

Protecting data on lost devices

- Encrypting sensitive data
- Encrypting entire file system
- Encrypting servers: third party solutions
- Enforce a self-destruction policy to destroy privileged data on a lost device
- Create a database action to delete the entire data on the user's device

Educating the Laptop users

- No free downloads
- Illegal music files and movies
- 86% employees do this
- Half of the companies have tools in place to manage the Internet access on laptops

Organizational Measures for Handling Mobile Device-Related Security Issues

- What organizations can do toward safeguarding their information systems in the mobile computing paradigm
- **Encrypting Organizational Databases**
- **Including Mobile Devices in Security Strategy**

Encrypting Organizational Databases

- Algorithms used to implement strong encryption of database files
  - Rijndael, a block encryption algorithm,
  - Multi-Dimensional Space Rotation Algorithm
- **Encrypting the database scrambles the information contained in the main database file**.
- Encryption Key is required whenever you want to start the database or you want to use a utility on your database
- **Self-destruction policy**: When a device that is identified as **lost or stolen** connects to the organization server, IT department can have the server send a package to **destroy privileged data on the device**

Including Mobile Devices in Security Strategy

- Make **devices lock or destroy** the lost data **by sending the machine a special message**
- Mobile devices have high-powered processors that will support 128-bit encryption
- A few things that enterprises can use are:
  - Implement **strong asset management, virus checking, loss prevention and other controls for mobile systems** that will prohibit unauthorized access and entry of corrupted data

Including Mobile Devices in Security Strategy

- A few things that enterprises can use are:
  - Investigate alternatives that allow a secure access to the company information through a **firewall**
  - Develop a system of more frequent and through **security audits for mobile devices**
  - Incorporate security awareness into your mobile training and support programs
  - Notify the appropriate law-enforcement agency and change passwords. **User accounts are closely monitored** for any unusual activity for a period of time

Organizational Security Policies and Measures in Mobile Computing Era

- Importance of Security Policies **relating to Mobile Computing Devices**
- Operating Guidelines for **Implementing Mobile Device Security Policies**
- Organizational Policies for **Use of Mobile Hand-Held Devices**

Importance of Security Policies relating to Mobile Computing Devices

- **Not to keep** credit card and bank account numbers, passwords, confidential E-Mails and strategic information about organizations, merger or takeover plans and stock values
- Prevent users from **storing proprietary information** on platforms deemed to be insufficiently secure by increasing awareness of the users
- Information classification and handling policy should **clearly define** what sorts of data may be stored on mobile devices
- Simply **not storing confidential data** on at-risk platforms **will mitigate the risk** of theft or loss

Operating Guidelines for Implementing Mobile Device Security Policies

1. **Determine** whether the employees in the organization need to **use mobile computing devices at all**
2. Implement **additional security technologies, authentication and encryption**
3. **Standardize the mobile computing devices** and the associated security tools
4. Develop a specific **framework for using** mobile computing devices
5. **Centralized management** of your mobile computing devices

Operating Guidelines for Implementing Mobile Device Security Policies

6. Establish **patching procedures for software** on mobile devices
7. Label the devices and **register them**
8. Establish procedures to **disable remote access** for any mobile devices reported as **lost or stolen**
9. **Remove data from computing devices** that are not in use or before reassigning those devices to new owners
10. Provide **education and awareness training** to personnel using mobile devices

Organizational Policies for Use of Mobile Hand-Held Devices

- One way is Creating a **distinct** mobile computing **policy**
- Another way is **including such devices under existing policy**
- **Hybrid approach**: mobile devices fall under both existing general policies and a new one
- In the hybrid approach, a new policy is created to **address the specific needs** of the mobile devices but more general usage issues fall under general IT policies

Laptops

- Pose a large Cybersecurity threat as
  - Portable
  - Wireless capability
  - Theft of laptops
- Countermeasures against theft of Laptops

Physical Security Countermeasures

- Cable and hardwired **locks**
  - One end of the security cable is fit into the **universal security slot of the laptop** and the other end is locked around any **fixed furniture** or item
  - These cables come with a variety of options such as number locks, key locks and alarms
- Laptop safes
  - Safes made of polycarbonate, that is used in **bulletproof**

Physical Security Countermeasures

- Motion sensors and alarms
  - **Alarm device** attached to the laptop transmits radio signal to a certain range
  - Owner of the laptop has a **key ring device** that communicates with laptop alarm device
  - The **alarm is triggered when distance** between the laptop alarm device and the key ring device **crosses** the specified range
  - PCMCIA cards that act as motion detector , an alarm system, and also have the capability to lockdown the laptop

Physical Security Countermeasures

- Warning labels and stamps
  - Contain **tracking information and identification** details **fixed** onto the laptop
  - These labels have an identification number that is stored in a universal database for verification
- Other measures for protecting laptops
  - **Engraving** the laptop with personal details
  - Keeping the laptop **close to oneself** wherever possible
  - **Carrying** the laptop in a **different and unobvious bag**

Physical Security Countermeasures

- Other measures for protecting laptops
  - Creating the awareness among the employees to understand the responsibility of carrying a laptop
  - Making a **copy of purchase receipt** with serial number
  - Installing **encryption software** to protect information stored
  - Using personal **firewall** software
  - **Updating the antivirus** software
  - **Disabling IR ports and wireless cards** and removing PCMCIA cards when not in use

Information Systems Security also contains Logical Access Controls

- **Protecting** from malicious programs / attackers / social engineering
- **Avoiding** weak password / open access
- **Monitoring** application security and scanning for vulnerabilities
- Ensuring that unencrypted data / unprotected file systems do not pose threats
- **Proper handling** of removable drives / storage mediums / unnecessary ports

Information Systems Security also contains Logical Access Controls

- **Password protection** through appropriate password rules and use of strong passwords
- **Locking down unwanted ports / devices**
- Regularly **installing security patches** and updates
- **Installing antivirus software / firewalls / intrusion detection system**
- **Encrypting critical file systems**

Information Systems Security also contains Logical Access Controls

- Other Countermeasures
  - Choosing **secure OS**
  - **Registering the laptop with the manufacturer**
  - Disabling unnecessary user accounts
  - **Disabling display** of the **last logged in** username
  - **Backing up data** on a regular basis